HTTP Saldırı Tespit Modeli: Bir İstek Üzerinden Öznitelikler

Makine Öğrenmesine Giriş · Modelin girdi öznitelikleri · 13 Ekim 2026

1. Amaç

Random Forest ve lojistik regresyon modelleri HTTP isteğinin metnini doğrudan okumaz. Her istek önce **21 sayısal özniteliğe** çevrilir; model yalnızca bu sayıları görür. Bu rapor, veri kümesindeki gerçek bir istek üzerinden her özniteliğin neyi ölçtüğünü ve değerinin nasıl hesaplandığını gösterir.

2. Örnek istek

Örnek, CSIC 2010 veri kümesinden alınmıştır (kayıt `anomalousTrafficTest.txt:987`, eğitim kümesinde, etiketi **anormal**). Bir alışveriş sitesinin kayıt formuna gönderilen POST isteğidir. Saldırgan şehir alanına (**ciudad**) sunucuya gizli bir dosyayı sayfaya eklemesini söyleyen bir komut (SSI enjeksiyonu) yerleştirmiştir.

```
POST /tienda1/publico/registro.jsp HTTP/1.1
User-Agent: Mozilla/5.0 (compatible; Konqueror/3.5; Linux) KHTML/3.5.8 (like Gecko)
Pragma: no-cache
Cache-control: no-cache
Accept:
text/xml,application/xml,application/xhtml+xml,text/html;q=0.9,text/plain;q=0.8,image/png,*/*;q=0.5
Accept-Encoding: x-gzip, x-deflate, gzip, deflate
Accept-Charset: utf-8, utf-8;q=0.5, *;q=0.5
Accept-Language: en
Host: localhost:8080
Cookie: JSESSIONID=04D7A9C3850CF728EC90AA963EF20DC5
Content-Type: application/x-www-form-urlencoded
Connection: close
Content-Length: 278

modo=registro&
login=zander&
password=arca%EDsta&
nombre=Zain&
apellidos=Espriella+Morcos&
email=skala%40lamarsrl.la&
dni=28264646S&
direccion=Nardo%2C+106%2C+7-H&
ciudad=%3C%21--%23include+file%3D%22archivo_secreto%22+--%3E&
cp=46315&
provincia=Alicante&
ntc=5436324330428646&
B1=Registrar
```

Gövde (son 13 satır) okunabilirlik için & işaretlerinden bölünmüştür; gerçekte tek satırdır ve 278 karakterdir.

3. İsteğin ayrıştırılması

Öznitelikler hesaplanmadan önce istek üç parçaya ayrılır: **yol** (`/tienda1/publico/registro.jsp`, 29 karakter), **sorgu** (bu istekte boş) ve **gövde**. Gövde `ad=değer` çiftlerine bölünür ve yüzde kodlaması çözülür (örneğin `%3C` → <, `+` → boşluk). Bu istekten 13 parametre çıkar:

Parametre	Çözülmüş değer	Uzunluk
`modo`	`registro`	8
`login`	`zander`	6
`password`	`arcaísta`	8

Parametre	Çözülmüş değer	Uzunluk
nombre	Zain	4
apellidos	Espriella Morcos	16
email	skala@lamarsrl.la	17
dni	28264646S	9
direccion	Nardo, 106, 7-H	15
ciudad	<!--#include file="archivo_secreto" -->	39
cp	46315	5
provincia	Alicante	8
ntc	5436324330428646	16
B1	Registrar	9
Toplam	13 değer	**160**

Karakter sayımları ve örüntü aramaları bu çözülmüş değerler üzerinde yapılır. Parametre adları, başlıklar (User-Agent, Cookie vb.) ve HTTP metodu öznitelik olarak kullanılmaz.

4. Yirmi bir öznitelik ve bu istekteki değerleri

Öznitelik	Ne ölçer	Değer	Bu istekte nereden geliyor
Boyut ve yapı			
path_length	Yolun karakter sayısı	**29**	/tienda1/publico/registro.jsp
query_length	Sorgu metninin karakter sayısı	**0**	Adreste ? ile başlayan sorgu yok
body_length	Gövdenin karakter sayısı (ham hali)	**278**	Kodlanmış gövde 278 karakter
query_param_count	Sorgudaki parametre sayısı	**0**	Sorgu boş
body_param_count	Gövdedeki parametre sayısı	**13**	modo, login, …, B1
duplicate_param_count (elendi)	Aynı adla tekrar eden parametre sayısı	**0**	13 adın hepsi farklı
max_value_length	En uzun parametre değerinin uzunluğu	**39**	ciudad değeri 39 karakter
mean_value_length	Değerlerin ortalama uzunluğu	**12,308**	160 / 13
Kodlama			
percent_encoding_count	Sorgu ve gövdedeki %XX kodlarının sayısı	**11**	%ED, %40, 2 × %2C ve ciudad içinde 7 kod
percent_encoding_ratio	Kodlanmış karakterlerin ham metne oranı	**0,119**	3 × 11 / 278
Karakter sayımları (çözülmüş değerlerde)			
quote_count	Tek ve çift tırnak sayısı	**2**	file="archivo_secreto" içindeki 2 çift tırnak
angle_bracket_count	< ve > sayısı	**2**	<!-- ve -->
semicolon_count	Noktalı virgül sayısı	**0**	Yok
control_char_count (elendi)	Kontrol karakteri sayısı (ASCII 0–31, 127)	**0**	Yok

Öznitelik	Ne ölçer	Değer	Bu istekte nereden geliyor
`digit_ratio`	Rakamların tüm değer karakterlerine oranı	**0,206**	33 rakam / 160 (dni, direccion, cp, ntc)
`whitespace_ratio`	Boşlukların tüm değer karakterlerine oranı	**0,031**	5 boşluk / 160
Saldırı örüntüleri (çözülmüş yol ve değerlerde)			
`sql_keyword_count`	SQL anahtar kelimesi sayısı (select, union, where, from…)	**0**	Yok
`sql_comment_marker_count`	SQL yorum işareti sayısı (--, /*, */)	**2**	<!-- ve --> içindeki iki -- dizisi
`path_traversal_count` (elendi)	../ veya ..\ dizisi sayısı	**0**	Yok
`script_tag_present`	<script etiketi var mı (0/1)	**0**	Yok
`ssi_marker_present`	<!--# işareti var mı (0/1)	**1**	ciudad değeri <!--#include ile başlıyor

Kırmızı zeminli değerler doğrudan enjekte edilen ciudad parametresinden kaynaklanır. "(elendi)" yazan 3 öznitelik eğitim kümesindeki bütün isteklerde aynı değeri aldığı için bilgi taşımaz; iki model de bunları atıp kalan 18 özniteliği kullanır.

5. Modelin gördüğü şey

Bütün bu işlemlerden sonra model için bu istek yalnızca 18 sayıdan oluşan bir satırdır:

```
[29 ; 0 ; 278 ; 0 ; 13 ; 39 ; 12,30769 ; 11 ; 0,11871 ; 2 ; 2 ; 0 ; 0,20625 ; 0,03125 ; 0 ; 2 ; 0 ; 1]
```

Random Forest bu sayıları olduğu gibi kullanır. Lojistik regresyon ölçeğe duyarlı olduğu için önce her sayıya log(1 + x) dönüşümü ve standart ölçekleme uygulanır. Etiket (anormal), kayıt kimliği ve kaynak dosya adı modele verilmez; etiket yalnızca eğitimde öğrenilecek cevap olarak kullanılır.

6. Sınırlar

• Öznitelikler isteğin biçimini özetler, anlamını değil. Bu örnekte sql_comment_marker_count 2 çıkmıştır, oysa istekte SQL yoktur; sayılan şey HTML yorumundaki -- dizileridir. Örüntüler kesin saldırı kanıtı değil, göstergedir.

• Başlıklar, çerez, HTTP metodu ve parametre adları taranmaz; saldırı yalnızca oralardaysa öznitelikler bunu yansıtmaz.

• Yalnızca form kodlamalı gövdeler ayrıştırılır; JSON ve multipart gövde desteği yoktur.

• Yüzde kodlaması bir kez çözülür; çift kodlanmış saldırılar çözülmüş haliyle görülmez.